# เอกสารประกอบการปฏิบัติการ

# รายวิชา CP423324 Database and Web Security

# Lab 5: PHP กับฐานข้อมูล MySQL 2

**วัตถุประสงค์**

1. เพื่อให้นักศึกษาสามารถดึงข้อมูลตามรหัส (ID) เพื่อแสดงในแบบฟอร์มแก้ไขได้
2. เพื่อให้นักศึกษาสามารถแก้ไขข้อมูลในฐานข้อมูลด้วยคำสั่ง UPDATE ได้
3. เพื่อให้นักศึกษาสามารถลบข้อมูลในฐานข้อมูลด้วยคำสั่ง DELETE ได้
4. เพื่อให้นักศึกษาสามารถใช้ MySQLi Prepared Statement กับคำสั่ง SELECT, UPDATE และ DELETE ได้

**คำชี้แจง**

1. ให้นักศึกษา Capture ผลลัพท์ตามที่งานของแต่ละข้อกำหนดลงใน Word และบันทึกไฟล์เป็น PDF โดยให้ตั้งชื่อว่า Lab05_รหัสนักศึกษา(มีขีด).pdf
2. เมื่อทำเสร็จเรียบร้อยแล้วให้แจ้งผู้ช่วยสอน (TA) เพื่อขอรับการตรวจและตอบคำถาม (กรุณาตรวจกับพี่ TA โดยคะแนนจะมาจากการตรวจในห้องเรียน)
3. เมื่อตรวจกับ TA เรียบร้อยแล้วให้นักศึกษาส่งใน Classroom เพื่อเป็นการสำรองข้อมูล
4. ไม่อนุญาตให้ส่งงานย้อนหลังได้ ยกเว้นกรณีลาป่วย หรืออุบัติเหตุ (ต้องมีใบรับรองแพทย์)

★★★★★★★★★

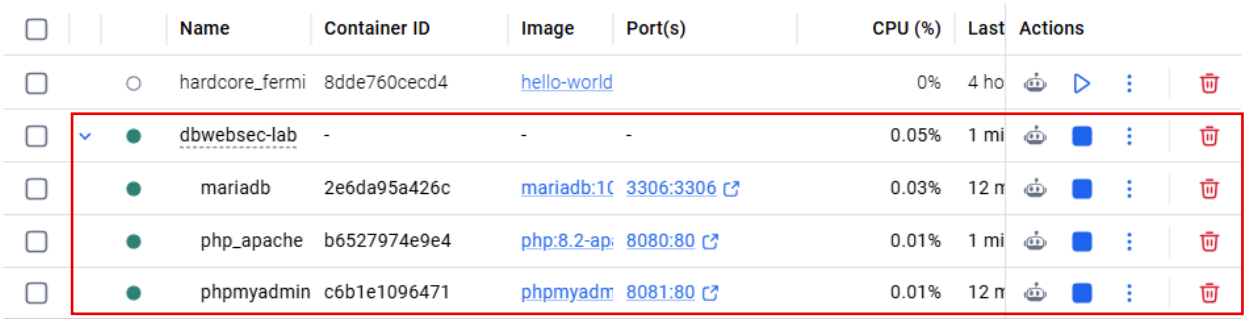
**โจทย์ที่กำหนด**

งานของปฏิบัติการนี้ เป็นการสร้างเว็บแอปพลิเคชันของระบบสำหรับบันทึกคำขอรับคำปรึกษาด้านการเรียน (Academic Advising Request System) โดยมีการแก้ไขคำสั่งและสร้างไฟล์เพิ่มเติมต่อจาก Lab04 สำหรับส่วนที่เพิ่มเติม 2 ส่วน ได้แก่ Update สำหรับแก้ไขข้อมูลคำขอรับคำปรึกษา และ Delete สำหรับลบข้อมูลที่เลือก โดยต้องใช้ Prepared Statement และตรวจสอบค่า ID ฝั่ง Server

หมายเหตุ: Lab05 ใช้ตารางเดิมจากตารางเดิมของ Lab04 ไม่ต้องสร้างฐานข้อมูลหรือตารางใหม่

โดยมีขั้นตอน ดังนี้

1. เปิด docker ที่เคยสร้างไว้ ให้ Start container name: dbwebsec-lab, mriadb, php_apache และ phpmyadmin



2. ให้นักศึกษาคัดลอกโฟลเดอร์ Lab04 แล้วเปลี่ยนชื่อเป็น Lab05 หรือสร้างโฟลเดอร์ Lab05 ไว้ภายใน C:\dbwebsec-lab\www สำหรับไฟล์ที่นำมาจากโฟลเดอร์ Lab04 ให้เปลี่ยนชื่อไฟล์ Lab04_... ให้เปลี่ยนเป็น Lab05_...) โดยในโฟลเดอร์ Lab05 จะต้องมีไฟล์ทั้งหมด 7 ไฟล์ มีรายละเอียด ดังนี้

1) Lab05_config.php แก้ไขไฟล์เดิมของ Lab04 สำหรับเชื่อมต่อฐานข้อมูลและเก็บฟังก์ชันที่ใช้ซ้ำ
2) Lab05_index.php แก้ไขไฟล์เดิมของ Lab04 สำหรับแสดงรายการข้อมูล พร้อมปุ่ม Edit และ Delete
3) Lab05_create.php ใช้ไฟล์เดิมจาก Lab04 สำหรับแสดงแบบฟอร์มเพิ่มข้อมูล
4) Lab05_store.php ใช้ไฟล์เดิมจาก Lab04 สำหรับรับค่าจากแบบฟอร์ม ตรวจสอบข้อมูล และบันทึกข้อมูลลงฐานข้อมูล
5) Lab05_edit.php รับค่า ID ดึงข้อมูลเดิมจากฐานข้อมูล และแสดงแบบฟอร์มสำหรับแก้ไขข้อมูล
6) Lab05_update.php รับค่าจากแบบฟอร์ม ตรวจสอบข้อมูล และอัปเดตข้อมูลด้วยคำสั่ง UPDATE
7) Lab05_delete.php รับคำขอแบบ POST ตรวจสอบค่า ID และลบข้อมูลด้วยคำสั่ง DELETE

2.1 ให้สร้างไฟล์ชื่อ Lab05_config.php เพื่อเก็บค่ากำหนดของระบบและฟังก์ชันที่ใช้ซ้ำ โดยไฟล์นี้จะถูกเรียกใช้จาก Lab05_index.php, Lab05_create.php, Lab05_store.php, Lab05_edit.php, Lab05_update.php และ Lab05_delete.php

```php
<?php
declare(strict_types=1);

const DB_HOST = 'db';
const DB_PORT = 3306;
const DB_NAME = 'db_lab04'; //ใช้ฐานข้อมูลจาก Lab04
const DB_USER = 'root';
const DB_PASS = 'root';

mysqli_report(MYSQLI_REPORT_ERROR | MYSQLI_REPORT_STRICT);

try {
    $conn = new mysqli(DB_HOST, DB_USER, DB_PASS, DB_NAME, DB_PORT);
    $conn->set_charset('utf8mb4');
} catch (mysqli_sql_exception $e) {
    http_response_code(500);
    error_log($e->getMessage());
    exit('Database connection failed. Please check Lab05_config.php');
}

function h(?string $value): string
{
    return htmlspecialchars(
        $value ?? '',
        ENT_QUOTES | ENT_SUBSTITUTE,
        'UTF-8'
    );
}

```

```php
function topicLabel(string $topic): string
{
    $labels = [
        'study_plan'   => 'Study Plan',
        'registration' => 'Course Registration',
        'project'      => 'Project',
        'other'        => 'Other',
    ];

    return $labels[$topic] ?? $topic;
}
// [เพิ่มใน Lab05] การตรวจสอบข้อมูลที่กรอกเข้ามา
/**
 * รายการค่าหัวข้อที่ระบบอนุญาต
 */
function allowedTopics(): array
{
    return ['study_plan', 'registration', 'project', 'other'];
}

/**
 * ตรวจสอบข้อมูลคำขอรับคำปรึกษา
 */
function validateAdvisingRequest(
    string $fullname,
    string $studentId,
    string $email,
    string $topic,
    string $message
): array {
    $errors = [];

    if ($fullname === '') {
        $errors[] = 'Full Name is required.';
    } elseif (mb_strlen($fullname) > 50) {
        $errors[] = 'Full Name must not exceed 50 characters.';
    }

    if ($studentId === '') {
        $errors[] = 'Student ID is required.';
    } elseif (!preg_match('/^[0-9]{9}-[0-9]$/', $studentId)) {
        $errors[] = 'Student ID must be in the format 673380000-1.';
    } elseif (mb_strlen($studentId) > 20) {
        $errors[] = 'Student ID must not exceed 20 characters.';
    }

```

```
    if ($email === '') {
        $errors[] = 'Email is required.';
    } elseif (!filter_var($email, FILTER_VALIDATE_EMAIL)) {
        $errors[] = 'Email format is invalid.';
    } elseif (mb_strlen($email) > 100) {
        $errors[] = 'Email must not exceed 100 characters.';
    }

    if (!in_array($topic, allowedTopics(), true)) {
        $errors[] = 'Please select a valid advising topic.';
    }

    $messageLength = mb_strlen($message);

    if ($message === '') {
        $errors[] = 'Message is required.';
    } elseif ($messageLength < 10) {
        $errors[] = 'Message must contain at least 10 characters.';
    } elseif ($messageLength > 500) {
        $errors[] = 'Message must not exceed 500 characters.';
    }

    return $errors;
}
```

2.2 ให้แก้ไขไฟล์ Lab05_index.php ให้เพิ่มคอลัมน์ ID และ คอลัมน์ Actions และสร้างปุ่ม Edit กับ Delete ในแต่ละแถว

```
<?php
declare(strict_types=1);
require_once 'Lab05_config.php';

$sql = 'SELECT id, fullname, student_id, email, topic, message, created_at
        FROM advising_requests
        ORDER BY created_at DESC';

$result = $conn->query($sql);

// [เพิ่มใน Lab05] รับค่า status จาก URL เพื่อใช้แสดงข้อความหลังเพิ่ม แก้ไข หรือลบข้อมูล
$status = $_GET['status'] ?? '';
?>
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Academic Advising Requests</title>
    <style>
        * { box-sizing: border-box; }
        body {
            margin: 0;
            font-family: Arial, sans-serif;
            background: #f3f6f9;
            color: #1f2937;
        }
        .container {
            width: min(1280px, 96%);
            margin: 40px auto;
        }
        .header {
            display: flex;
            justify-content: space-between;
            align-items: center;
            gap: 16px;
            margin-bottom: 20px;
        }
```

```
39      h1 { margin: 0; font-size: 28px; }
40      .subtitle { margin-top: 6px; color: #6b7280; }
41      .btn {
42          display: inline-block;
43          border: 0;
44          border-radius: 7px;
45          padding: 9px 13px;
46          color: white;
47          text-decoration: none;
48          font: inherit;
49          font-weight: bold;
50          cursor: pointer;
51      }
52      .btn-add { padding: 11px 18px; background: #198754; }
53      /* [เพิ่มใน Lab05] รูปแบบของปุ่ม Edit และ Delete */
54      .btn-edit { background: #0d6efd; }
55      .btn-delete { background: #dc3545; }
56
57      /* [เพิ่มใน Lab05] จัดปุ่ม Edit และ Delete ให้อยู่ในแถวเดียวกัน */
58      .actions {
59          display: flex;
60          align-items: center;
61          gap: 8px;
62          white-space: nowrap;
63      }
64      .actions form { margin: 0; }
65      /* [เพิ่มใน Lab05] กล่องข้อความแจ้งผลหลัง Create, Update และ Delete */
66      .alert {
67          margin-bottom: 18px;
68          padding: 13px 16px;
69          border: 1px solid #badbcc;
70          border-radius: 8px;
71          background: #d1e7dd;
72          color: #0f5132;
73      }
74      .card {
75          overflow-x: auto;
76          background: white;
77          border-radius: 12px;
78          box-shadow: 0 4px 18px rgba(0, 0, 0, 0.07);
79      }
80      table {
81          width: 100%;
82          border-collapse: collapse;
83          min-width: 1180px;
84      }
85      th, td {
86          padding: 13px 14px;
87          border-bottom: 1px solid #e5e7eb;
88          text-align: left;
89          vertical-align: top;
90      }
91      th {
92          background: #198754;
93          color: white;
94          white-space: nowrap;
95      }
96      tbody tr:hover { background: #f8fafc; }
97      .message {
98          min-width: 240px;
99          white-space: pre-wrap;
100     }
```

```
        .empty {
            padding: 32px;
            text-align: center;
            color: #6b7280;
        }
        @media (max-width: 700px) {
            .header {
                align-items: flex-start;
                flex-direction: column;
            }
        }
    </style>
</head>
<body>
<div class="container">
    <div class="header">
        <div>
            <h1>Academic Advising Requests</h1>
        </div>
        <a class="btn btn-add" href="Lab05_create.php">
            + Add New Request
        </a>
    </div>
    <!-- [เพิ่มใน Lab05] แสดงข้อความแจ้งผลตามค่า status -->
    <?php if ($status === 'created'): ?>
        <div class="alert">The advising request was created successfully.</div>
    <?php elseif ($status === 'updated'): ?>
        <div class="alert">The advising request was updated successfully.</div>
    <?php elseif ($status === 'deleted'): ?>
        <div class="alert">The advising request was deleted successfully.</div>
    <?php endif; ?>

    <div class="card">
        <?php if ($result->num_rows > 0): ?>
            <table>
                <thead>
                <tr>
                    <th>ID</th>
                    <th>Full Name</th>
                    <th>Student ID</th>
                    <th>Email</th>
                    <th>Topic</th>
                    <th>Message</th>
                    <th>Created At</th>
                    <!-- [เพิ่มใน Lab05] เพิ่มคอลัมน์สำหรับปุ่มแก้ไขและลบข้อมูล -->
                    <th>Actions</th>
                </tr>
                </thead>

      <tbody>
      <?php while ($row = $result->fetch_assoc()): ?>
          <tr>
              <td><?= h((string) $row['id']) ?></td>
              <td><?= h($row['fullname']) ?></td>
              <td><?= h($row['student_id']) ?></td>
              <td><?= h($row['email']) ?></td>
              <td><?= h(topicLabel($row['topic'])) ?></td>
              <td class="message"><?= h($row['message']) ?></td>
              <td><?= h($row['created_at']) ?></td>
              <!-- [เพิ่มใน Lab05] ส่วนคำสั่ง Edit และ Delete ของข้อมูลแต่ละแถว -->
              <td>
                  <div class="actions">
                      <!-- [เพิ่มใน Lab05] ปุ่ม Edit ส่ง ID แบบ GET ไปยัง Lab05_edit.php -->
                      <a class="btn btn-edit"
                          href="Lab05_edit.php?id=<?= h((string) $row['id']) ?>">
                          Edit
                      </a>

```

```
169         <!-- [เพิ่มใน Lab05] ปุ่ม Delete ส่ง ID แบบ POST ไปยัง Lab05_delete.php
170             และใช้ confirm() ให้ผู้ใช้ยืนยันก่อนลบ -->
171         <form action="Lab05_delete.php"
172             method="post"
173             onsubmit="return confirm('Are you sure you want to delete this request?');"
174         >
175             <!-- [เพิ่มใน Lab05] เก็บ ID ไว้ใน hidden input เพื่อส่งไปลบข้อมูล -->
176             <input
177                 type="hidden"
178                 name="id"
179                 value="<?= h((string) $row['id']) ?>"
180             >
181             <button class="btn btn-delete" type="submit">
182                 Delete
183             </button>
184         </form>
185                                 </div>
186                             </td>
187                         </tr>
188                     <?php endwhile; ?>
189                     </tbody>
190                 </table>
191             <?php else: ?>
192                 <div class="empty">No advising requests found.</div>
193             <?php endif; ?>
194         </div>
195     </div>
196     </body>
197     </html>
```

2.3 ให้สร้างไฟล์ชื่อ Lab05_edit.php รับค่า ID แล้วดึงข้อมูลเดิมจากฐานข้อมูล และมาแสดงแบบฟอร์มสำหรับแก้ไขข้อมูล สามารถคัดลอกส่วนของ CSS และหน้าฟอร์มจาก Lab05_create.php ได้

```php
<?php
declare(strict_types=1);
require_once  'Lab05_config.php';

$id = filter_input(INPUT_GET, 'id', FILTER_VALIDATE_INT);

if ($id === false || $id === null || $id <= 0) {
    http_response_code(400);
    exit('Invalid request ID.');
}

$sql = 'SELECT id, fullname, student_id, email, topic, message
        FROM advising_requests
        WHERE id = ?';

$stmt = $conn->prepare($sql);
$stmt->bind_param('i', $id);
$stmt->execute();

$result = $stmt->get_result();
$request = $result->fetch_assoc();
$stmt->close();

if (!$request) {
    http_response_code(404);
    exit('Advising request not found.');
}
?>
```

```
<!DOCTYPE html>
<html lang="en">
<head>
    <meta charset="UTF-8">
    <meta name="viewport" content="width=device-width, initial-scale=1.0">
    <title>Edit Advising Request</title>
    <style>
        * { box-sizing: border-box; }
        body {
            margin: 0;
            font-family: Arial, sans-serif;
            background: #f3f6f9;
            color: #1f2937;
        }
        .container {
            width: min(720px, 92%);
            margin: 40px auto;
        }
        .card {
            background: white;
            padding: 28px;
            border-radius: 12px;
            box-shadow: 0 4px 18px rgba(0, 0, 0, 0.08);
        }
        h1 { margin: 0 0 8px; font-size: 28px; }
        .subtitle { margin: 0 0 24px; color: #6b7280; }
        .form-group { margin-bottom: 18px; }
        label {
            display: block;
            margin-bottom: 7px;
            font-weight: bold;
        }
        input, select, textarea {
            width: 100%;
            padding: 11px 12px;
            border: 1px solid #cbd5e1;
            border-radius: 8px;
            font: inherit;
            background: white;
        }
        input:focus, select:focus, textarea:focus {
            outline: none;
            border-color: #0d6efd;
        }
        textarea {
            min-height: 130px;
            resize: vertical;
        }
```

```
        .hint {
            margin-top: 5px;
            color: #6b7280;
            font-size: 13px;
        }
        .buttons {
            display: flex;
            flex-wrap: wrap;
            gap: 10px;
            margin-top: 24px;
        }
        button, .back-link {
            border: 0;
            border-radius: 8px;
            padding: 11px 18px;
            font: inherit;
            font-weight: bold;
            cursor: pointer;
            text-decoration: none;
        }
        .update-btn { background: #0d6efd; color: white; }
        .reset-btn { background: #e5e7eb; color: #111827; }
        .back-link { background: #6c757d; color: white; }
    </style>
</head>
<body>
<div class="container">
    <div class="card">
        <h1>Edit Advising Request</h1>
        <p class="subtitle">
            Edit Request ID: <?= h((string) $request['id']) ?>
        </p>
        <form action="Lab05_update.php" method="post">
            <input type="hidden" name="id"
                value="<?= h((string) $request['id']) ?>" >

            <div class="form-group">
                <label for="fullname">Full Name</label>
                <input type="text" id="fullname" name="fullname"
                    maxlength="50" value="<?= h($request['fullname']) ?>" required >
            </div>

            <div class="form-group">
                <label for="student_id">Student ID</label>
                <input type="text" id="student_id" name="student_id"
                    maxlength="20" pattern="[0-9]{9}-[0-9]"
                    value="<?= h($request['student_id']) ?>" required >
                <div class="hint">Format: 9 digits, hyphen, and 1 digit</div>
            </div>

            <div class="form-group">
                <label for="email">Email</label>
                <input type="email" id="email" name="email"  maxlength="100"
                    value="<?= h($request['email']) ?>" required >
            </div>

            <div class="form-group">
                <label for="topic">Advising Topic</label>
                <select id="topic" name="topic" required>
                    <option value="">-- Select a topic --</option>
                    <option value="study_plan"
                        <?= $request['topic'] === 'study_plan' ? 'selected' : '' ?> >
                        Study Plan
                    </option>
                    <option value="registration"
                        <?= $request['topic'] === 'registration' ? 'selected' : '' ?> >
                        Course Registration
                    </option>
```

```
                    <option value="project"
                        <?= $request['topic'] === 'project' ? 'selected' : '' ?> >
                        Project
                    </option>
                    <option value="other"
                        <?= $request['topic'] === 'other' ? 'selected' : '' ?>>
                        Other
                    </option>
                </select>
            </div>

            <div class="form-group">
                <label for="message">Message</label>
                <textarea id="message" name="message" minlength="10" maxlength="500"
                  required ><?=h($request['message']) ?></textarea>
                <div class="hint">10–500 characters</div>
            </div>


            <div class="buttons">
                <button class="update-btn" type="submit">Update</button>
                <button class="reset-btn" type="reset">Reset</button>
                <a class="back-link" href="Lab05_index.php">
                    Cancel
                </a>
            </div>
        </form>
    </div>
</div>
</body>
</html>
```

2.3 ให้สร้างไฟล์ชื่อ Lab05_update.php เพื่อรับค่าจากแบบฟอร์ม ของไฟล์ Lab05_edit.php แล้วตรวจสอบข้อมูล และอัปเดตข้อมูลด้วยคำสั่ง UPDATE

```php
<?php
declare(strict_types=1);
require_once 'Lab05_config.php';

if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    header('Location: Lab05_index.php');
    exit;
}

$id = filter_input(INPUT_POST, 'id', FILTER_VALIDATE_INT);

if ($id === false || $id === null || $id <= 0) {
    http_response_code(400);
    exit('Invalid request ID.');
}

$fullname = trim($_POST['fullname'] ?? '');
$studentId = trim($_POST['student_id'] ?? '');
$email = trim($_POST['email'] ?? '');
$topic = trim($_POST['topic'] ?? '');
$message = trim($_POST['message'] ?? '');

$errors = validateAdvisingRequest(
    $fullname, $studentId, $email, $topic, $message );

if (!empty($errors)) {
    ?>
```

```
28      <!DOCTYPE html>
29      <html lang="en">
30      <head>
31          <meta charset="UTF-8">
32          <meta name="viewport" content="width=device-width, initial-scale=1.0">
33          <title>Validation Error</title>
34          <style>
35              body {
36                  margin: 0;
37                  font-family: Arial, sans-serif;
38                  background: #f3f6f9;
39                  color: #1f2937;
40              }
41              .container {
42                  width: min(650px, 92%);
43                  margin: 50px auto;
44              }
45              .error-box {
46                  padding: 25px;
47                  border: 1px solid #f5c2c7;
48                  border-radius: 10px;
49                  background: #f8d7da;
50                  color: #842029;
51              }

52              h1 { margin-top: 0; }
53              li { margin-bottom: 8px; }
54              .back-link {
55                  display: inline-block;
56                  margin-top: 15px;
57                  padding: 10px 18px;
58                  border-radius: 8px;
59                  background: #0d6efd;
60                  color: white;
61                  text-decoration: none;
62                  font-weight: bold;
63              }
64          </style>
65      </head>

66      <body>
67      <div class="container">
68          <div class="error-box">
69              <h1>Unable to update the request</h1>
70              <p>Please correct the following errors:</p>
71              <ul>
72                  <?php foreach ($errors as $error): ?>
73                      <li><?= h($error) ?></li>
74                  <?php endforeach; ?>
75              </ul>
76              <a
77                  class="back-link"
78                  href="Lab05_edit.php?id=<?= h((string) $id) ?>"
79              >
80                  Back to Edit Form
81              </a>
82          </div>
83      </div>
84      </body>
85      </html>
86      <?php
87      exit;
88  }
89
```

```php
$sql = 'UPDATE advising_requests
        SET fullname = ?,  student_id = ?, email = ?,  topic = ?, message = ?
        WHERE id = ?';

try {
    $stmt = $conn->prepare($sql);
    $stmt->bind_param(
        'ssssi',
        $fullname, $studentId, $email,$topic, $message, $id
    );
    $stmt->execute();

    if ($stmt->affected_rows === 0) {
        $checkSql = 'SELECT id FROM advising_requests WHERE id = ?';
        $checkStmt = $conn->prepare($checkSql);
        $checkStmt->bind_param('i', $id);
        $checkStmt->execute();

        $checkResult = $checkStmt->get_result();

        if ($checkResult->num_rows === 0) {
            $checkStmt->close();
            $stmt->close();
            http_response_code(404);
            exit('Advising request not found.');
        }

        $checkStmt->close();
    }

    $stmt->close();

    header('Location: Lab05_index.php?status=updated');
    exit;
} catch (mysqli_sql_exception $e) {
    http_response_code(500);
    error_log($e->getMessage());
    exit('Unable to update the advising request. Please try again.');
}
```

2.4 3 ให้สร้างไฟล์ชื่อ Lab05_delete.php เพื่อรับคำขอแบบ POST ตรวจสอบค่า ID และลบข้อมูลด้วยคำสั่ง DELETE

```php
<?php
declare(strict_types=1);
require_once 'Lab05_config.php';

if ($_SERVER['REQUEST_METHOD'] !== 'POST') {
    header('Location: Lab05_index.php');
    exit;
}

$id = filter_input(INPUT_POST, 'id', FILTER_VALIDATE_INT);

if ($id === false || $id === null || $id <= 0) {
    http_response_code(400);
    exit('Invalid request ID.');
}

$sql = 'DELETE FROM advising_requests WHERE id = ?';

```

```php
try {
    $stmt = $conn->prepare($sql);
    $stmt->bind_param('i', $id);
    $stmt->execute();

    if ($stmt->affected_rows === 0) {
        $stmt->close();
        http_response_code(404);
        exit('Advising request not found.');
    }

    $stmt->close();

    header('Location: Lab05_index.php?status=deleted');
    exit;
} catch (mysqli_sql_exception $e) {
    http_response_code(500);
    error_log($e->getMessage());
    exit('Unable to delete the advising request. Please try again.');
}
```

งานที่ 1.1 Capture หน้าจอผลลัพธ์ที่แสดง เมื่อกรอก URL

http://localhost:8080/Lab05/Lab05_index.php

จากนั้น คลิกที่ปุ่ม Edit ของแถวใดแถวหนึ่ง จากนั้นให้ Capture หน้าจอผลลัพธ์ที่แสดง

งานที่ 1.2 จากนั้นแก้ไขข้อความเป็นค่าใหม่ทุกช่อง แล้วคลิกที่ปุ่ม Update จากนั้นให้ Capture หน้าจอผลลัพธ์ที่แสดงในหน้า Academic Advising Requests

งานที่ 1.3 ให้เข้าไปที่ phpMyAdmin จากนั้น Capture หน้าจอผลลัพธ์ ที่ข้อมูลถูกแก้ไขในฐานข้อมูล

งานที่ 2.1 ให้ไปที่หน้า Academic Advising Requests แล้วคลิกที่ปุ่ม Edit ของแถวใดแถวหนึ่ง จากนั้นแก้ไขข้อมูล ดังนี้

Full Name: Bob Brown

Student ID: 673380001-2

Email: bob@kkumail.com

Advising Topic: Course Registration

Message: Help me

จากนั้น Capture หน้าจอผลลัพธ์ที่แสดง หลังจากกดปุ่มUpdate

งานที่ 2.2 จากนั้นแก้ไขข้อมูล ดังนี้

Full Name: Bob Brown

Student ID: 673380001-2

Email: bob@kkumail.com

Advising Topic: Course Registration

Message: <script>alert('XSS')</script>

จากนั้น Capture หน้าจอผลลัพธ์ที่แสดง หลังจากกดปุ่ม Update

งานที่ 3.1 ให้ไปที่หน้า Academic Advising Requests แล้วคลิกที่ปุ่ม Delete ของแถวใดแถวหนึ่ง จากนั้น Capture หน้าจอผลลัพธ์ที่แสดง

งานที่ 3.2 จากงานที่ 3.1 ให้คลิกที่ปุ่ม OK จากนั้น Capture หน้าจอผลลัพธ์ที่แสดง หลังจากกดปุ่ม Submit

งานที่ 3.3 ให้เข้าไปที่ phpMyAdmin จากนั้น Capture หน้าจอผลลัพธ์ ที่ข้อมูลถูกลบออกจากฐานข้อมูล

